Data Protection Impact Assessment (DPIA) — Zienswijzer

Controller: Deploying public body (the organisation installing Zienswijzer). **Processor:** The deploying body operates the instance on its own infrastructure and is both controller and (self-)processor. Gradient is the software vendor and has no access to live data unless a separate Data Processing Agreement (Art. 28 GDPR) is in place. **Date:** 2026-06-05 **Application:** Zienswijzer — WOO case & document management.

1. Description of processing

Zienswijzer processes WOO (Wet Open Overheid) requests, the documents attached to them, and correspondence with stakeholders. It organises these into cases and workspaces and classifies stakeholder replies (agree/object to publication).

2. Categories of data subjects and personal data

- **Requesters / correspondents:** name, email address, message content.
- **Stakeholders:** name, organisation, contact details, submitted views.
- **Document content:** may contain personal data of third parties referenced in WOO documents.
- **Authentication:** application user accounts (username, session).

Email integration uses Microsoft Graph (OAuth) under the deploying body's own Azure AD tenant; mailbox data is accessed under the scopes the body grants.

3. Purpose and lawful basis

Processing supports a legal obligation (handling WOO requests) and the public-interest task of the public body (Art. 6(1)(c)/(e) GDPR). AI classification assists human case handlers; it does not make automated decisions with legal effect.

4. Necessity and proportionality

Only data necessary to triage and publish WOO material is processed. AI inference runs in-cluster (no third-party transfer). Data residency: EU.

5. Data flows and storage

- SQLite database inside the cluster (`/app/server/db`), optionally on a PVC.
- Session data in ephemeral storage.
- Email accessed via Microsoft Graph over TLS; nothing exported outside the EU.

6. Risks and mitigations

Risk	Mitigation
Exposure of third-party personal data in documents	Access control; human review before publication.
Unauthorised access	Authenticated app; cluster RBAC; secrets in Vault, never in values.yaml.
Misclassification by AI	Limited-risk assistive use; human case handler decides.
Data in transit	TLS at the Ingress (opt-in via `ingress.tls.enabled=true`; the deploying body MUST enable it for production); in-cluster service traffic.
Credential leakage	MICROSOFT_* credentials delivered via Kubernetes Secret / platform Vault.

7. Data retention

The application does not impose an automatic retention period. Under the storage- limitation principle (Art. 5(1)(e) GDPR), the deploying body is responsible for defining and enforcing a retention/deletion policy for WOO correspondence and documents in line with its archival and disclosure obligations.

8. Residual risk and DPO sign-off

Residual risk assessed **low** given human oversight and EU-only processing.

DPO sign-off

- Name: _____
- Role / Organisation: _____
- Date: _____
- Signature: _____